

Table of Contents

GRC Risk Register and Risk Treatment Practice Manual práctico

Versión 1.0 - Agosto 2026

Author: Alberto “Al” Leiva

ChatGPT ayudó bajo la dirección del autor. El autor sigue siendo responsable de las decisiones editoriales y de liberación.

Aviso de uso educativo

Este manual y sus herramientas de acompañamiento son recursos educativos. Deben adaptarse a los objetivos de la organización, apetito de riesgo, obligaciones legales y contractuales, sistemas, datos, autoridad de decisión y contexto operativo. No constituyen asesoramiento jurídico, contable, reglamentario, de certificación ni de auditoría formal.

Cómo utilizar este manual

Utilice los capítulos para establecer un nuevo registro de riesgos. Los programas existentes pueden utilizar secciones individuales para la calidad de escenario, puntuación, tratamiento, aceptación, monitoreo o mejora de gobernanza. Preserve la lógica, evidencia, propiedad, aprobaciones y historial de revisión de cada decisión de riesgo material.

1. Risk Management Foundations

Propósito

Un registro de riesgos es un registro de decisiones controlado. Se documentan hechos o condiciones inciertas que podrían afectar objetivos, las pruebas utilizadas para evaluarlos, la respuesta seleccionada por los líderes responsables y las medidas necesarias para mantener la exposición dentro de los límites aprobados.

Un registro debe apoyar las decisiones en lugar de convertirse en una lista estática de preocupaciones. Cada entrada debe ser lo suficientemente específica para que otra persona calificada pueda entender el escenario, reproducir la lógica de evaluación, identificar al propietario responsable, y determinar si el tratamiento está progresando.

Conceptos básicos

Objetivo

El resultado empresarial, misión, servicio, cumplimiento, seguridad, seguridad, privacidad, financiero o operacional que podría verse afectado.

Situación de riesgo

Una descripción concisa de cómo una amenaza, condición, dependencia, decisión o oportunidad podría afectar a un objetivo. Una estructura útil es:

Debido a ** causa o condición, evento** puede ocurrir, dando lugar a **consecuencia a un objetivo**.

Riesgo hereditario

La exposición estimada antes de examinar la eficacia de los controles existentes. Las organizaciones deben definir si el riesgo inherente no asume controles, sólo controles de base u otra condición declarada.

Controles existentes

Políticas, procesos, tecnologías, contratos, capacitación, supervisión u otras medidas que ya operan para modificar la probabilidad o el impacto.

Riesgo residual

La exposición restante después de considerar el diseño y la eficacia operativa de los controles existentes.

Riesgo objetivo

La exposición prevista después de las acciones de tratamiento aprobadas se completa y verifica.

Riesgo de apetito y tolerancia

El apetito de riesgo expresa la cantidad y el tipo de riesgo que una organización está dispuesta a perseguir o retener en apoyo de objetivos. La tolerancia establece límites mensurables o una variación aceptable en torno a esos objetivos. Las entradas fuera de la tolerancia requieren una intensificación, tratamiento, transferencia, evitación o aceptación formalmente autorizada.

Principios de gobernanza

1. Vincular cada riesgo material a un objetivo.
2. Assign one accountable risk owner, even when many teams contribute.
3. Pruebas separadas del juicio.
4. La incertidumbre y las hipótesis del Estado explícitamente.
5. Utilice escalas definidas de forma consistente.
6. No promedia las consecuencias graves sin la racionalidad documentada.
7. Record who accepted residual risk and the acceptance period.

8. Evaluar después de cambios materiales, incidentes, fallos de control o nueva información.
9. Mantener la trazabilidad de apoyar pruebas y cuestiones conexas.
10. Escalar el tratamiento atrasado y expirar la aceptación automáticamente o mediante un proceso de revisión documentado.

Funciones

— Papel permanente Silencio... Silencio Consejo de Administración o comité ejecutivo tención Aprueba el apetito, la tolerancia y decisiones de riesgo importantes Silencioso propietario Silencio Contable para entender y gestionar el riesgo Propietario de control Silencio Accountable for design, operation, and evidence of a control TEN Silencio Propietario de acción Silencio Complete una tarea de tratamiento específica Silencio Función de riesgo Silencio Define la metodología, evaluaciones de desafíos e informes de exposición de cartera TENIDO Función de Assurance TENIDO Evalua de manera independiente la gobernanza, los controles y la evidencia Silencio Experto en materia de prevención de la muerte Proporciona información técnica, jurídica, operacional, financiera u otra información especializada TEN

Prueba de calidad mínima

Una entrada de riesgo no está lista para la aprobación a menos que identifique el objetivo afectado, describe un escenario plausible, cita evidencia, asigna un propietario, registra los controles actuales, estima probabilidad e impacto utilizando criterios definidos, estados exposición residual, selecciona una respuesta, e incluye una fecha de revisión.

2. Determinación del riesgo y Escenario

Determinar los riesgos de los objetivos

Comience con el objetivo, no con una lista genérica de amenazas. Examinar objetivos estratégicos, servicios críticos, obligaciones jurídicas y contractuales, activos clave, datos importantes, terceras partes importantes, proyectos, cambios y dependencias conocidas.

Los insumos de identificación útiles incluyen:

- Objetivos empresariales y de misión
- Análisis del impacto empresarial
- Diagramas de arquitectura y flujo de datos
- Inventarios de bienes y servicios
- Inteligencia de amenazas e historia de incidentes
- Resultados de auditoría y pruebas de control
- Datos de vulnerabilidad y configuración
- Evaluaciones de los proveedores y los riesgos de concentración
- Requisitos reglamentarios y contractuales
- Cambio de carteras y planes de transformación
- Denuncias, cerca de señoritas, excepciones y eventos de pérdida

Estructura escenario

Un escenario de riesgo defensible contiene cuatro elementos:

1. **Contexto o causa** — la condición que crea exposición.
2. **Evento** — qué puede pasar.
3. **Objetivo o activo afectado** — lo que importa a la organización.
4. **Consecuencia** — el daño creíble o la oportunidad perdida.

Ejemplo:

Debido a que las cuentas privilegiadas no se revisan de forma sistemática, un privilegio no autorizado o excesivo puede permanecer activo, permitiendo el acceso inapropiado a información confidencial del cliente y causando daños regulatorios, financieros y de reputación.

Evitar declaraciones débiles

Las entradas débiles incluyen palabras sencillas como “ransomware”, “riesgo de los vendedores”, o “incumplimiento”. No explican la consecuencia del negocio ni apoyan una evaluación repetible.

Reescribir declaraciones vagas pidiendo:

- ¿Qué condición hace posible el evento?
- ¿Qué evento podría ocurrir?
- ¿Qué objetivo, servicio, activo o obligación se ve afectada?
- ¿Cuál es la consecuencia creíble?
- ¿Qué evidencia apoya el escenario?

Taxonomía de riesgo

Una taxonomía ayuda a las entradas agregadas sin sustituir el análisis de escenarios. Las categorías pueden incluir:

- Estratégico
- Operaciones
- Ciberseguridad
- Privacidad
- Legal and regulatory
- Financiera
- Tecnología
- Tercera parte y cadena de suministro
- Resiliencia y continuidad
- Seguridad
- Workforce
- Reputación

- Proyecto y cambio

Utilizar categorías primarias y secundarias cuando un escenario abarca varios dominios.

Pruebas e hipótesis

Cada escenario material debe citar pruebas tales como informes, entradas, evaluaciones, contratos, resultados de pruebas, registros de incidentes, métricas o análisis de expertos. Las hipótesis de registro por separado para que los encargados de adoptar decisiones puedan distinguir los hechos conocidos de las estimaciones.

Ejemplos de hipótesis:

- Un servicio seguirá dependiendo de un proveedor durante los próximos doce meses.
- Un control funciona como diseñado entre pruebas trimestrales.
- Una estimación de frecuencia de amenazas se basa en datos sectoriales más que en la historia interna.

Identificadores de entrada y relaciones

Asignar identificadores estables como RR-2026-001. No recicle identificadores. Enlace de registros relacionados, incluyendo:

- Controles
- Conclusiones
- Incidentes
- Excepciones
- Proyectos
- Vendedores
- Activos
- Políticas
- Acciones de tratamiento
- Decisiones de riesgo aceptado

Método del taller de identificación

1. Definir el objetivo y el alcance.
2. Presentar pruebas actuales y limitaciones conocidas.
3. Identificar causas, eventos y consecuencias.
4. Consolidar duplicados sin perder causas o impactos distintos.
5. Assign provisional owners.
6. Hipótesis de documentos y deficiencias de pruebas.
7. Enviar entradas para validación antes de anotar.

Un taller no debe forzar el consenso promediando opiniones incompatibles. Se debe registrar y intensificar el desacuerdo material para que se adopte una decisión.

3. Risk Analysis and Scoring

Definir el método antes de anotar

Las organizaciones deben documentar sus criterios de probabilidad, impacto y riesgo antes de evaluar las entradas individuales. Un modelo de puntuación apoya la priorización pero no reemplaza el juicio profesional o las decisiones de gobernanza.

Escala de probabilidad

Una escala práctica de cinco niveles puede usar frecuencia, probabilidad o evidencia cualitativa.

Silencio Silencio Silencio Silencio Silencio Silencio... Silencio 1 – Rare – Excepcional circumstances; little supporting evidence Silencio 2 Silencio A diferencia de la vida podría ocurrir, pero no se espera en condiciones normales Silencio 3 Silencio Posible Silencio Credible y puede ocurrir durante el período de evaluación Silencio Silencio 4 Silencio Supuestamente esperando que ocurra o ha ocurrido repetidamente Silencio 5 Silencio Casi cierta Silencio Se espera con frecuencia o ya está ocurriendo

La organización debería definir el período de evaluación y los umbrales mensurables donde los datos lo permitan.

Escala de impacto

Evaluar el impacto en las dimensiones relevantes, luego aplicar la regla de agregación documentada.

Silencio Silencio Silencio Silencio Silencio interpretación general Silencio Silencio... Silencio 1 – Insignificante – Interrupción o pérdida mínimas; manejo de rutina Silencio 2 Silencio Menor Silencio Impacto limitado; manejable dentro de las operaciones normales Silencio 3 Ø Moderate Silencioso material perturbación, costo o preocupación por el cumplimiento que requiere atención de gestión Silencio 4 Silencio Principal TENIDO Daño grave a objetivos, clientes, operaciones, finanzas o obligaciones TENIDO Silencio 5 – Severe Silencioso empresarial, seguridad de la vida, consecuencia sistémica o catastrófica

Las dimensiones de impacto comunes incluyen impacto financiero, operativo, legal y regulatorio, privacidad, seguridad, cliente, estratégico y reputación.

Marcas compuestas

Una matriz simple puede calcular:

$\text{Risk score} = \text{Likelihood} \times \text{Impact}$

Bandas de ejemplo:

- 1–4: Bajo
- 5–9: Moderado
- 10–16: Alto
- 17–25: crítico

Estas bandas son ilustrativas. La organización debe aprobar sus propios umbrales y normas de escalada.

Limitaciones importantes

La multiplicación puede crear falsa precisión. Una puntuación de 12 puede representar probabilidad 3 e impacto 4 o probabilidad 4 e impacto 3, aunque las implicaciones de la gobernanza pueden diferir. Preserve las calificaciones subyacentes y la racionalidad.

No permita que una probabilidad baja oculte un impacto severo intolerable. Defina reglas de anulación para la seguridad de la vida, prohibiciones legales, concentración sistémica, fallo de servicio crítico u otras consecuencias no negociables.

Evaluación del control

Evaluar el diseño de control y la eficacia de funcionamiento por separado.

- **Eficacia del diseño** ¿El control, si opera como está previsto, modificaría materialmente el riesgo?
- **Operación de la eficacia** ¿Es el control implementado consistentemente y apoyado por pruebas actuales?

Use fechas de evidencia, resultados de pruebas, excepciones, cobertura y niveles de confianza. No trate la existencia de una política como prueba de que un control funciona eficazmente.

Riesgo residual

El riesgo residual debe reflejar la eficacia evaluada de los controles actuales. Grabación:

- Preferencias residuales
- Impacto residual
- Puntaje o nivel residual
- Confianza en la estimación
- Suposiciones clave
- Fecha de prueba
- Deficiencias de control conocidas

Confianza e incertidumbre

Añade un campo de confianza como alto, mediano o bajo. Los riesgos de alto impacto de baja confianza a menudo requieren análisis adicionales en lugar de una prioridad menor.

Cuestiones de examen de calidad

- ¿Se definen las escalas y se aplican sistemáticamente?
- ¿Está claro el período de evaluación?
- ¿La evidencia apoya las calificaciones?
- ¿Se consideraron múltiples dimensiones de impacto?
- ¿Se evaluó por separado el diseño y operación de control?

- ¿Es visible la incertidumbre y el desacuerdo?
- ¿El resultado se alinea con el apetito y la tolerancia?

4. Respuesta al riesgo, tratamiento y aceptación

Seleccione una respuesta

Las respuestas comunes incluyen:

- *Evitar* Parar, rediseñar o rechazar la actividad creando la exposición.
- *Mitigate* Reduzca la probabilidad, el impacto o ambos mediante controles o cambios de proceso.
- **Transferencia o participación** Asignar consecuencias definidas a otra parte mediante seguros, contratos, asociaciones u otro mecanismo. La rendición de cuentas generalmente no puede transferirse por completo.
- **Acepto:** Retener la exposición residual mediante una decisión autorizada y con plazos.
- **Pursue or enhance:** Para los riesgos relacionados con las oportunidades, tome medidas para aumentar la probabilidad o beneficio al tiempo que controle la exposición al inconveniente.

La respuesta seleccionada debe ser coherente con el apetito, la tolerancia, las obligaciones jurídicas, los contratos, la ética y la autoridad organizativa.

Requisitos del plan de tratamiento

Un plan de tratamiento debe identificar:

- Respuesta y justificación seleccionadas
- Riesgo de destino deseado
- Acciones específicas y entregables
- Propietarios
- Recursos necesarios y presupuesto aprobado
- Dependencias y limitaciones
- Hitos y fechas debidas
- Medidas de éxito
- Pruebas necesarias para el cierre
- Efecto previsto en la probabilidad y el impacto
- Controles provisionales cuando el tratamiento final tomará tiempo
- Criterios de escalada

Evite acciones vagas como “mejorar seguridad” o “vendedor de vigilancia”. Escribe acciones que pueden ser probadas y cerradas.

Prueba de calidad de acción

Una acción de tratamiento sólo se completa cuando el ejecutable requerido existe, el propietario responsable proporciona evidencia, el control o cambio se valida, y el riesgo se vuelve a evaluar. Completar una tarea de proyecto no prueba automáticamente que el riesgo se redujo.

Aceptación de riesgos

La aceptación nunca debe estar implícita por la inacción. Un registro oficial de aceptación debería incluir:

- Identificador de riesgo y nivel residual actual
- El titular de la decisión y la base de autoridad
- Racionalidad empresarial
- Declaración de apetito o tolerancia aplicable
- Condiciones y controles compensatorios
- Fechas de inicio y expiración de la aceptación
- Necesidades de supervisión
- Eventos que requieren una pronta reconsideración
- Notificaciones requeridas
- Pruebas de firma o aprobación auditable

La aceptación expedida debe volver al estado de revisión hasta que se renueva, trate, evite, transfiera o cierre.

Excepciones

Una excepción de política o control puede crear o aumentar el riesgo. Vincular excepciones al registro de riesgo pertinente e incluir el alcance, la justificación, la autoridad de aprobación, los controles compensatorios, la fecha de vencimiento y el plan de rehabilitación.

Supervisión del tratamiento

Pista al menos:

- Acciones abiertas y atrasadas
- Estado de Milestone
- Cambios en la exposición
- Control de la aplicación y pruebas de prueba
- Limitaciones presupuestarias o de recursos
- Fallos de dependencia
- Caducidad de la aceptación
- Amenazas emergentes o hipótesis modificadas

Criterios de cierre

Un riesgo puede cerrarse cuando el escenario ya no es aplicable, el objetivo o la actividad ha terminado, o el tratamiento verificado ha reducido la exposición por debajo del umbral de cierre de la organización. Preserve el registro histórico, la racionalidad del cierre, evidencia, aprobador y fecha de cierre.

No cierre un riesgo simplemente porque la fecha de vencimiento pasó o el propietario cambió.

5. Vigilancia, presentación de informes y escalada

Frecuencia de revisión

La frecuencia de examen debe reflejar la exposición, volatilidad, estado de tratamiento y necesidades de decisión. Los riesgos críticos o rápidamente cambiantes pueden requerir revisión continua o mensual. Los riesgos bajos estables pueden ser revisados trimestral o anual. Definir frecuencias mínimas y desencadenantes de revisión impulsados por eventos.

Revise un riesgo temprano cuando:

- Un incidente significativo o una falta cercana ocurre
- Un control falla o su cobertura cambia
- Un sistema, proceso, proveedor, ley, contrato o cambios objetivos importantes
- Un hito de tratamiento se pierde
- An acceptance approaches expiration
- Cambios materiales de amenaza o pérdida de información
- El riesgo se mueve fuera del apetito o la tolerancia

Principales indicadores de riesgo

Un indicador clave de riesgo debe proporcionar pruebas oportunas de que la exposición está cambiando. Cada indicador necesita un propietario, fuente, cálculo, umbral, frecuencia de recogida y regla de escalada.

Por ejemplo:

- Porcentaje de sistemas críticos sin planes de recuperación probados
- Número de cuentas privilegiadas atrasadas para su examen
- Concentración de servicios críticos con un proveedor
- vulnerabilidades de alta resistencia más allá del período de rehabilitación aprobado
- Porcentaje de medidas de tratamiento atrasadas
- Número de aceptaciones de riesgo vencidas

Situación y tendencia

Rastrear el nivel actual y la dirección por separado.

- **Improving:** La evidencia indica que la exposición está disminuyendo.
- **Establece:** Sin cambios materiales.
- **Deterioro:** La exposición, la incertidumbre, la debilidad del control o el retraso está aumentando.
- **Desconocido:** La evidencia es insuficiente o estable.

Una tendencia desconocida no equivale a un riesgo estable.

Escala

Escalar cuando un riesgo:

- Excede el apetito o la tolerancia
- Alcanza un nivel crítico
- No tiene dueño responsable
- Ha debido tratamiento de alta prioridad
- Depende de la financiación o autoridad no disponibles
- Incluye una prohibición legal, preocupación por la seguridad o obligación obligatoria de presentar informes
- Tiene una aceptación vencida
- Muestra desacuerdo material que no se puede resolver a nivel actual

El registro debe determinar el receptor de escalada, el plazo requerido y la decisión solicitada.

Presentación de informes

Los diferentes públicos necesitan diferentes puntos de vista.

Vista operacional

Incluye acciones detalladas, pruebas, estado de control, fechas debidas y dependencias.

Vista de la administración

Destaca los principales riesgos, tendencias, tratamiento atrasado, excepciones y decisiones necesarias.

Vista de los órganos rectores

Se centra en la exposición relativa a objetivos, apetito y tolerancia, concentración, riesgo emergente, dependencias sistémicas y decisiones importantes.

Análisis de cartera

Riesgos agresivos cuidadosamente. Utilice taxonomía, objetivos, unidades de negocio, servicios, proveedores y dependencias de control para identificar la concentración y la exposición sistémica. Preserve trazabilidad a escenarios subyacentes.

Evite summing ordinal puntuaciones como si fueran valores financieros a menos que la metodología apoye explícitamente ese cálculo.

Controles de calidad de los datos

Monitor:

- Propietarios desaparecidos
- Falta de pruebas
- Fechas de examen atrasadas
- Aceptaciones arrastradas
- Escenarios incompletos
- Calificaciones inconsistentes
- Riesgos duplicados
- Medidas no vinculadas
- Acciones cerradas sin validación
- Cambios sin soporte para puntuaciones

Reunir disciplina

Una reunión de examen del riesgo debería centrarse en las decisiones, los cambios de pruebas, las excepciones, las medidas atrasadas y la escalada. No pase la reunión leyendo cada campo en voz alta. Record decisions, owners, due dates, and dissent.

6. Procedimiento operativo y Ejemplo de trabajo

Procedimiento final a fin

Paso 1 - Establecer el alcance

Definir el objetivo, proceso, servicio, proyecto, unidad de negocio, grupo de activos, población de proveedores o decisión que se evalúa. Confirme el período de evaluación, metodología, criterios de calificación y autoridad de decisión.

Paso 2 - Reunir pruebas

Recopilar documentos actuales, informes del sistema, incidentes, resultados de pruebas, métricas, contratos, información de arquitectura y insumos especializados. Registro de fechas y lagunas.

Paso 3 - Escribir escenarios

Describir causa, evento, objetivo afectado y consecuencia. Separar escenarios materialmente diferentes en lugar de combinar exposiciones no relacionadas.

Paso 4 - Asignación de la propiedad

Nombre uno responsable de riesgo. Identificar a los propietarios de control y acción por separado.

Paso 5 - Evaluar la exposición inherente

Aplicar los criterios aprobados de probabilidad e impacto utilizando la suposición de riesgo inherente.

Paso 6 - Evaluar los controles

Documentar los controles pertinentes y evaluar el diseño y la eficacia operativa utilizando pruebas.

Paso 7 - Evaluar la exposición residual

Estimar la probabilidad y el impacto restantes. Confianza récord, suposiciones e incertidumbre.

Paso 8 - Compara con el apetito y la tolerancia

Determinar si la exposición está dentro de los límites aprobados y si es necesaria una escalada.

Paso 9 - Seleccione respuesta y tratamiento

Elija evitar, mitigar, transferir/compartir, aceptar o perseguir/enhance. Definir acciones mensurables y la exposición al objetivo.

Paso 10 - Aprobar y supervisar

Obtenga la decisión necesaria, vigile indicadores y acciones, reevalúe después del cambio y preserve pruebas.

Ejemplo trabajado

Objetivo

Mantener el acceso continuo a la plataforma de soporte al cliente durante períodos críticos para el negocio.

Escenario

Debido a que la plataforma depende de una sola región de la nube y las pruebas de recuperación no han demostrado la restauración dentro del requisito del negocio, una perturbación regional del servicio puede hacer que la plataforma no esté disponible, retrasando el apoyo al cliente y causando daños contractuales, financieros y de reputación.

Pruebas

- Diagrama de arquitectura actual
- Análisis del impacto empresarial
- Informe de la prueba de recuperación

- Documentación del servicio Cloud-provider
- Compromisos de disponibilidad del contrato de cliente

Evaluación inicial

- Probablemente: 3 - Posible
- Impacto: 5 — Severe
- Puntuación: 15 — Alto bajo la matriz de ejemplo

Controles existentes

- Respaldos nativos del proveedor
- Configuración de infraestructura almacenada en control de versiones
- Procedimientos de respuesta a incidentes
- Supervisión de la página

Evaluación del control

El diseño es parcialmente efectivo porque las copias de seguridad y la recuperación de soporte de configuración, pero no existe capacidad de registro secundario. La eficacia operativa es parcialmente eficaz porque se supervisan los trabajos de copia de seguridad, mientras que la restauración completa no ha cumplido el tiempo necesario de recuperación.

Evaluación residual

- Probablemente: 3 - Posible
- Impacto: 4 - Mayor
- Puntuación: 12 — High
- Confianza: Medio
- Estado de competencia: Tolerancia exterior

Respuesta

Mitigate.

Acciones de tratamiento

1. Diseñar y aprobar la arquitectura de secundaria.
2. Implementar datos replicados y la automatización de despliegue probada.
3. Realizar un ejercicio completo de recuperación.
4. Procedimientos de actualización y comunicaciones de clientes.
5. Validar el tiempo de recuperación y los objetivos del punto de recuperación.

Evaluación de objetivos

- Objetivo de probabilidad: 2 - A diferencia
- Impacto objetivo: 3 - Moderado
- Meta: 6 - Moderado

Supervisión

Seguimiento de resultados de recuperación, fracasos de replicación sin resolver, hitos de arquitectura y tareas de tratamiento atrasadas. Escalar los hitos perdidos o cualquier superación de la tolerancia aprobada.

Fallos comunes en la aplicación

- Tratar la puntuación como el riesgo más que el escenario
- Assigning groups instead of accountable owners
- Controles de grabación sin pruebas
- Aceptar el riesgo indefinidamente
- Acciones de clausura sin reevaluación de la exposición
- Usando pruebas de estancamiento
- Combinar muchos riesgos no relacionados en un solo registro
- La presentación de informes sólo cuenta en lugar de decisiones y concentración

Aceptación del riesgo Record

Información sobre riesgos

- ID de riesgo:
- Título de riesgo:
- Objetivo afectado:
- Propietario del riesgo:
- Preferencias residuales actuales:
- Impacto residual actual:
- Nivel residual actual:
- Confianza en la evaluación:

Decisión

- Decisión: Aceptar / Aceptar condicionalmente / Rechazar solicitud de aceptación
- Propietario autorizado de la decisión:
- Base de la autoridad:
- Fecha de la decisión:
- Fecha efectiva:
- Fecha de expedición:

Rationale

Describir por qué mantener la exposición está justificada, incluido el valor comercial esperado, las alternativas disponibles, el costo y la viabilidad, y las consecuencias de la demora.

Appetite and tolerance

- Declaración de apetito aplicable:

- Tolerancia o umbral aplicable:
- Estado: dentro / fuera / Excepciones aprobadas

Condiciones y controles compensatorios

List required safeguards, restrictions, monitoring, communications, and dependencies.

Supervisión

- Principales indicadores de riesgo:
- Umbral:
- Propietario de vigilancia:
- Frecuencia de revisión:
- Ubicación de la prueba:

La reconsideración temprana desencadena

Ejemplos incluyen un incidente material, fallo de control, cambio legal o contractual, mayor exposición, cambio de objetivo, condición perdida o nueva información sobre amenazas.

Notificaciones requeridas

Identificar órganos rectores, ejecutivos, clientes, reguladores, aseguradores, partes contractuales o funciones internas que deben ser informadas.

Pruebas de aprobación

Grabar la firma, billete, decisión de reunión, aprobación electrónica u otra autorización auditable.

Resultado del examen

- Fecha de revisión:
- Resultado: Renovar / Tratar / Evitar / Transferencia o compartir / Cerrar
- Condiciones actualizadas:
- Propietario de acción siguiente:
- Fecha siguiente:

Autoritative Source Register

Revisado el 1 de agosto de 2026.

Fuentes primarias

1. NIST IR 8286 Rev. 1, *Integrating Cybersecurity and Enterprise Risk Management (ERM)*, Diciembre 2025. <https://csrc.nist.gov/pubs/ir/8286/r1/final>
2. NIST IR 8286A Rev. 1, *Identificando y Estimando Riesgo de Ciberseguridad para la Gestión del Riesgo Empresarial*, Diciembre 2025. <https://csrc.nist.gov/pubs/ir/8286/a/r1/final>

3. NIST IR 8286B, *Prioritizing Cybersecurity Risk for Enterprise Risk Management*. <https://csrc.nist.gov/pubs/ir/8286/b/final>
4. NIST IR 8286C, *Staging Cybersecurity Risks for Enterprise Risk Management and Governance Oversight*. <https://csrc.nist.gov/pubs/ir/8286/c/final>
5. NIST SP 800-30 Rev. 1, *Guide for Conducting Risk Assessments*. <https://csrc.nist.gov/pubs/sp/800/30/r1/final>
6. NIST Cybersecurity Framework 2.0. <https://www.nist.gov/cyberframework>
7. ISO 31000:2018, * Gestión de Riesgos — Directrices*. ISO identifica la edición 2018 como actual y señala que la edición 3 está en desarrollo. <https://www.iso.org/standard/65694.html>
8. Center for Internet Security, CIS RAM v2.2 family of documents for CIS Controls v8.1. <https://learn.cisecurity.org/cis-ram-v2-2>

Uso y limitaciones

Este manual resume las prácticas generales de gestión de riesgos y no reproduce las normas. Las organizaciones deben verificar los requisitos actuales, las condiciones de concesión de licencias, las obligaciones específicas de cada sector y su propia metodología aprobada antes del uso.